

INFORMATION SECURITY POA: CONCISE NOTES

Chapter – 1: Information Asset Protection (IAP)

1. Information Protection.

1.1. Information assets consist of sensitive and proprietary information, privacy-protected data, intellectual property, intangible assets, and information defined under international, federal, and state laws governing trade secrets, patents, and copyrights.

1.2. ***Information asset protection (IAP)***, also known as information security or protection of proprietary information.

2. Risk Management Approach to IAP.

2.1. Risk assessment process for use in IAP:

2.1.1. Identify information assets.

2.1.2. Value information assets

2.1.3. Assess threats to information assets & assess likely adversaries.

2.1.4. Assess the likelihood of occurrence of threats.

2.1.5. Identify existing and projected vulnerabilities.

2.1.6. Assess the impact of a loss event or disclosure on the organization.

2.1.7. Identify existing and planned security controls for addressing risk.

2.1.8. Assess and prioritize risks, based on their likelihood and impact.

2.2. ***The goal of security program is to optimize risk, never minimize it.***

3. **Threat Categories.** Intentional, Natural, Inadvertent.

3.1. Intentional Threats.

3.1.1. Foreign and domestic competitors, foreign governments, activist groups, terrorist groups, criminal enterprises, information brokers, and vandals.

3.1.2. To assess intentional threats, potential adversaries should be identified and evaluated based on their capability and intention to target key information assets.

3.2. **Natural Threats.** All small and large organizations should prepare for natural threats that can severely affect their operations, because, without an effective preparedness plan that includes off-site critical data backup and warm or hot sites, they may dissolve.

3.3. Inadvertent Threats.

3.3.1. Inadvertent threats can be attributed to inadequate employee training, misunderstanding, lack of attention to detail, lax security enforcement, the pressure to produce a deliverable, insufficient staffing, or other factors.

3.3.2. ***Most frequently overlooked & most difficult to identify and evaluate.***

4. Approaches to Risk mitigation.

4.1. **Basic Protection Practices.**

4.1.1. **FBI Approach.** The FBI (2011) lists the following steps for protecting a business from espionage:

- Recognize there is an insider and outsider threat to your company.
- Identify and value trade secrets.
- Implement a proactive plan for safeguarding trade secrets.
- Secure physical and electronic versions of your trade secrets.
- Confine intellectual knowledge on a “need-to-know” basis.
- Provide training to employees about your company’s intellectual property plan and security.

4.1.2. **IAP Policies & Awareness.** Clear, practical, and well-designed policies strengthen the security program.

- Steps when developing a policy.
- Commitment of the leadership by providing resources and requiring all units to develop strategies to align goals.
- A dedicated department, group, or individuals should be tasked with policy management and auditing.
- adherence to the policy.
- Training should be delivered repeatedly & should be documented.

4.1.3. **Identification & Marking of Protected Information.**

- Levels are used to **distinguish the degree of sensitivity** or the **degree of protection warranted: confidential, restricted, limited, non-public, public.**
- The **originator of the information or Data Owner** determines the classification level.
- Access to internal information should be restricted to company personnel or others who have signed a Non-Disclosure Agreement (NDA).

4.2. **Physical Security.**

4.2.1. **Layered Security (Defence in Depth).** Defence in depth can be viewed from three different perspectives, in which the concentric rings or layers of protection represent the following:

- Increasing levels of trust for those who are given access to successive layers.
- Different security technologies or measures that operate in concert.
- Successive layers employed to delay, detect, and deter intruders.
- **Implementation of IAP.** To implement layered protection, an IAP professional should do the following:
 - Apply multiple levels or layers of protective measures
 - Ensure that successive levels or layers of protective measures complement rather than conflict with each other
 - Build a coordinated strategy that integrates different families of protective measures.

4.2.2. **Protection of Information in Physical Form.**

- **Prototypes and Models.**

- These should be afforded all the same physical security, access controls, classification, employee vetting, verification, and documentation as other information assets.
- Obsolete prototypes, models, and test items should be destroyed so they cannot be reversed engineered.
- Contractors or vendors entrusted with prototypes, models, or test items should be contractually bound to protect them according to the owner's policies and procedures.

- **Manufacturing processes and equipment**

- Access to production or processing facilities should be restricted.
- Photography in production or processing areas should be restricted.
- Contractors with access to the production or processing area should have executed nondisclosure agreements.

4.3. **Personnel Security.**

4.3.1. Personnel security includes due diligence investigations of potential partners, standard pre-employment screening, and vetting of subcontractors, vendors, and consultants.

4.3.2. The **screening process** is **handled by the legal or human resources** department.

4.4. **Operations Security or Information Risk Management.**

4.4.1. Operations security (OPSEC) is a protection approach developed in the military to protect unclassified information that could reveal sensitive plans and operations.

4.4.2. It **aims towards identifying any protection gaps** that remain despite current security measures.

4.4.3. OPSEC responds to the fact that **small bits of information taken from several different sources can be combined to reveal sensitive information.**

5. **Legal Protections.**

5.1. Privacy-protected information is specifically regulated by the Health Insurance Portability and Accountability Act (HIPAA), the Privacy Act, and the Financial Services Modernization Act (Gramm-Leach-Bliley Act) in the United States.

5.2. Information asset owners must recognize that legal protections are effective only if the owner is willing to pursue recourse when a violation occurs.

5.3. The best way to start addressing infringement of patents, copyrights, and trademarks is to **register those rights.**

5.4. **Copyright.**

5.4.1. A copyright is used to protect the expression of ideas in literary, artistic, and musical works.

5.4.2. Under international law, copyrights do not have to be registered to be protected.

5.5. Trademark.

5.5.1. A trademark consists of words, names, symbols, devices, or images applied to products or used in connection with goods or services to identify their source.

5.5.2. Registration of trade- marks is the primary means of ensuring that the mark is eligible for protection.

5.5.3. Trade secret is not disclosed and may last indefinitely.

5.6. Patent.

5.6.1. A property right granted to an inventor to exclude others from making, using, offering for sale, or selling the invention for a limited time.

5.6.2. **A patent lasts only 20 years.**

5.6.3. No criminal laws regarding patent infringement.

5.7. Trade Secret.

5.7.1. Trade secrets need not be registered with any outside agency, so the owner can maintain a greater degree of control over the asset.

5.7.2. For information to be considered a trade secret, the owner must be able to prove that the information added **value or benefit** to the owner, the trade **secret was specifically identified**, and the owner provided a reasonable level of **protection** for the trade secret.

6. Technical Protective Measures.

6.1. **Technical Surveillance Countermeasures (TSCM).** Technical surveillance countermeasures (TSCM) are services, equipment, and techniques designed to locate, identify, and neutralize technical surveillance activities and should be part of an organization's overall protection strategy.

6.2. Protection in IT Environment.

6.2.1. **Logical network access control.** This the process by which users are identified and granted privileges to information, systems, or resources.

6.2.2. **Sanitizing information systems and media.** Sanitizing is the process of removing data on a storage medium (such as a hard drive) before the medium is reused. Methods include **overwriting and degaussing** (magnetic erasure) and **physical destruction**.

6.2.3. **Encryption.** Encryption obscuring the meaning of information by altering or encoding it in such a way that it can only be decoded by people for whom it is intended.

7. Information Classification.

<u>Unrestricted</u>	<u>Internal Use</u>	<u>Restricted</u>	<u>Highly Restricted</u>
Information that can be shared inside and outside organization.	Information generated within the organization that is not intended for public distribution.	Information that is organizationally or competitively sensitive or that could introduce	Proprietary information that could allow a competitor to take action that could seriously damage our competitive position or could

		legal or employee privacy risks.	significantly damage the organization's financial or competitive position.
	Access generally limited to employees.	Access for employees is based on the individual's role.	Access for employees is limited to specifically authorized individuals.
	Control & Updates managed by the content owner.	Content owners manage access lists and authorize sharing.	Content owners manage access lists for type of access and authorized sharing.
			Quarterly review of continued access.

8. Examples of Information.

<u>Unrestricted</u>	<u>Internal Use</u>	<u>Restricted</u>	<u>Highly Restricted</u>
Factual information contained in organization's advertising & on its Web sites.	• Organization charts • Employee directories • Maps of the facilities	• Pre-patent data • Safety data • Product initiative reports • Customer data • Consumer insights • Personnel information • Sourcing plans	• Developmental formulas • Patent data • Consolidated financials • Stock actions • Global financial system information • Flagship brand strategy

Chapter – 2: Increasing Importance of Information Security Systems

1. Implications to Physical Security in a Converged World.

- 1.1. Convergence allows physical security devices to interact across a network for substantial organizational gains.
- 1.2. Legacy systems are gradually being replaced by new **SCADA [supervisory control and data acquisition]** systems that use the Internet as the control backbone.
- 1.3. Physical security can use several modes of communication.
 - 1.3.1. A proprietary connection between one device and another.
 - 1.3.2. An industry-standard connection between two devices, such as the Weigand protocol between a card reader and controller.
 - 1.3.3. A TCP/IP (transmission control protocol/Internet protocol), the worldwide Internet standard for communication.
 - 1.3.4. Devices are divided into two types of systems, **embedded and host-based**.
 - 1.3.5. **Embedded** systems (also known as special systems) are typically programmed at the manufacturer and run proprietary or nonstandard operating systems.

1.3.6. **Host-based** systems run on more standard operating systems, typically a Windows or Linux operating system.

Chapter – 3: Information Security Systems

1. Information Security Systems.

1.1. The objective of an organization's information systems security (ISS) program is to prudently and cost-effectively manage the risk that critical organizational information could:

- be compromised,
- be changed without authorization,
- become unavailable.

1.2. Security professional strives to protect information's **confidentiality, integrity, and availability** (CIA Triad).

1.3. The fundamental equation of ISS.

1.3.1. **Residual Risk = Threats x Vulnerabilities / Countermeasures**

1.3.2. This equation is intended to be qualitative, not quantitative.

1.3.3. It says that **residual risk rises as threats arise and as vulnerabilities rise and decreases as countermeasures are applied.**

2. Information Systems Threats.

2.1. Categories: **Nature, People, Virtual threat**

2.2. **Virtual Threat.**

2.2.1. A virtual threat agent is the equivalent of a ghost in the network, acting on behalf of its real-world owner, it steals, changes, or destroys an organization's information or misuses its system.

2.2.2. Virtual threats take advantage of the very logic of modern computer and communications Systems.

2.2.3. Some virtual threats are:

- **Marketing Spyware:** collecting information about Web sites visited, sending the information to its owner, and displaying pop-ups.
- **Key Loggers:** recording keystrokes and sending the data to their owner.
- **Koobface:** a computer worm that targets people who use social networking sites.

3. **Information System Vulnerabilities.** ISS vulnerabilities fall into these broad categories:

3.1. **Vulnerabilities in the information systems infrastructure**, such as inappropriate links to unprotected networks, improper system configuration, or unpatched workstations.

3.2. **Vulnerabilities in people using the information systems infrastructure (users)**, meaning users allow other people, via social engineering or other means, to access their computers.

3.3. **Vulnerabilities in people maintaining the information systems infrastructure (custodians)**, including too many permissions, inadequate monitoring and logging of actions, and inadequate training.

3.4. **Executive and senior management vulnerabilities**, including lack of accountability, inadequate policies and procedures, inadequate security awareness training, inadequate third-party management, and physical vulnerabilities.

4. **Information System Control Objectives.** The four control objectives must be met: the protection of corporate **assets, detection, recovery, and compliance.**

5. **Information Security Countermeasures.**

5.1. Information systems countermeasures can be divided into three broad classifications:

5.1.1. **Administrative controls:** management, policies, standards, procedures, guidelines, personnel screening, awareness training, etc.

5.1.2. **Technical controls:** network log-ins and passwords, firewalls, audit logs, encryption, antivirus, and spam filters.

5.1.3. **Physical controls:** door locks, cameras, environmental controls, guards, etc.

5.2. **Infrastructure countermeasures** are controls placed on the information system infrastructure to prevent the exploitation of threats.

5.2.1. **Perimeter security**, including devices that create or secure a perimeter, such as switches, firewalls, etc.

5.2.2. **Device protection security**, including specific protection on devices (antivirus, desktop firewalls, encrypted hard drives, etc.)

5.2.3. **Access control and authentication**, including making sure a person is authorized before they can do anything on a device (user IDs, passwords, second-factor key fobs, etc.)

5.3. **Information Systems Infrastructure Management Countermeasures** include systemic rules for protecting the entire system. They include the following:

5.3.1. **Vulnerability and patch management** to address any known vulnerabilities on one's system.

5.3.2. **System monitoring and log review** to know what is happening on one's systems and be able to forensically investigate anything that occurs.

5.3.3. **Information systems security metrics** to ensure that one can measure the success one's endeavours.

5.3.4. **Physical security of the information systems infrastructure** to make sure people cannot gain physical access to systems.

5.3.5. **IT staff training in information security** to make sure that those to whom an organization entrusts its systems are properly trained.

6. **Open Systems Interconnect (OSI).** All modern communications via computer follow the Open Systems Interconnect (OSI) Seven Layer Network Model, developed by the International Organization for Standardization.

6.1. **The seven layers of the OSI model are as follows:** Application, Presentation, Session, Transport, Network, Data Link, Physical

6.1.1. **Layer 1:** At the physical layer, computers are communicating by either sending an electrical impulse or not.

6.1.2. **Layer 2:** In layer 2 communication, computers can only speak to each other when they can directly contact each other.

6.1.3. **Layer 3:** At the network layer, computers are unable to see each other directly. This layer was created so machines that could not immediately see each other could still communicate.

6.1.4. **Remaining Layers:**

- The other four layers of the OSI model are also important in understanding the way computers interact.
- The transport layer determines the mechanism for how computers are actually going to transport the information between the two computers now that they can talk.
- The last three layers—session, presentation, and application—address how computers organize data into flows, standardize the data, and perform functions not pertaining directly to network operation.

6.2. **AAA Triad.** Authentication, Authorization and auditing. Authentication can be confirmed by **Passwords, Second factors, Name title.**

7. **CIA Triad.**

7.1. **Confidentiality.**

7.1.1. One mechanism for increasing security is to use an additional authentication factor beyond the user name and password. Example: biometric authentication, second-factor authentication in the form of one-time password (OTP).

7.1.2. Another mechanism for ensuring confidentiality is **encryption**.

7.1.3. One of the earliest known methods of encryption is called the **Caesar cipher**, where individuals use a grid on each end of the encryption method allowing them to move a letter forward a certain number of positions from the actual message.

7.2. **Integrity.**

7.2.1. Encryption can also help with integrity because it is very difficult to modify something that one cannot read.

7.2.2. Another tool for maintaining integrity is a **Cyclical Redundancy Check (CRC)**, which shows whether data has been tampered with.

7.3. **Availability.**

7.3.1. If users cannot get their data, it is not of much use.

7.3.2. If data disappears, it is not available. It can also disappear by being stolen.

7.3.3. A basic tenet of computing is to back up data off-site, preferably in a data storage vault.

8. Information Security Technologies.

8.1. Intrusion detection system (IDS).

8.1.1. Monitor one's network and attempt to decipher either via behaviour or patterns/signatures whether someone is trying to attack the system.

8.1.2. Variation of the IDS is an intrusion prevention system (IPS), which is designed to automatically stop an attack in progress.

8.2. Host intrusion protection system (HIPS)

8.2.1. This is like an IDS except that it operates on a host system, such as a computer or server.

8.2.2. HIPS is an evolution of host protection from antivirus.

8.3. Certificates

8.3.1. A mechanism by which individuals who do not know each other can ensure a secure transaction.

8.3.2. Asymmetric tools that work like a lock and key, allowing individuals to exchange information securely over a non-trusted channel.

8.4. Security information and event manager (SIEM)

8.4.1. A device that looks at all the log activity on a network, and attempts to point out what is most important to facilitate response to incursions and other problems on the network.

8.5. E-mail gateway

8.5.1. A device that looks at the inbound and outbound e-mail to determine whether it is a security risk.

8.5.2. One purpose is to reduce the amount of spam, or unwanted e-mail, that comes into a network.

8.6. Web gateway/proxy server

8.6.1. They filter which Web pages can be downloaded.

8.6.1. They may keep users from accessing particular sites, such as pornographic sites, or work as a proxy, or intermediary, that removes pages that might have malicious content.

8.7. Data loss protection (DLP)

8.7.1. Keeps people from sending certain data, such as trade secrets or other intellectual property, off the network, either inadvertently or on purpose.

8.8. Network access control (NAC)

8.1. A technology by which computers are not admitted to a network unless they are allowed, do not have any malicious software and meet the standards of the network.

8.9. Common Vulnerabilities and Exposures (CVE)

8.9.1. An on-line dictionary of publicly known information security vulnerabilities and exposures.

8.9.2. It forms the backbone of the National Vulnerability Database and is an essential tool in the twin disciplines of vulnerability management and patch management.

9. The Emerging Legal, Regulatory, and Contractual Landscape Regarding ISS

9.1. Payment Card Industry Data Security Standard (PCIDSS).

9.1.1. It is a worldwide information security standard defined by the Payment Card Industry Security Standards Council (2010).

9.1.2. The standard is designed to provide a uniform set of ISS standards for protecting the credit card information.

9.1.3. The standard applies to all organizations that hold, process, or exchange cardholder information from any card branded with the logo of one of the preceding companies.

9.1.4. The standard contains 12 requirements organized into six broad categories.

9.2. Health Care and Insurance Portability & Accountability Act (HIPAA)

9.2.1. Includes key provisions relating to patients' privacy rights.

9.2.2. Insurance companies, doctors, hospitals, laboratories, and employers who maintain employee health plans are subject to HIPAA provisions.

9.2.3. HIPAA has been expanded and amended by the adoption of the ***Health Information Technology for Economic and Clinical Health (HITECH) Act in 2009.***

9.3. Gramm-Leach-Bliley Act (GLBA).

9.3.1. The GLBA, which regulates the use and disclosure of non-public personal information about individuals who obtain financial products or services from financial institutions.

9.3.2. Each agency or authority shall establish appropriate standards for the financial institutions subject to their jurisdiction relating to administrative, technical, and physical safeguards.

9.4. Children's Online Privacy Protection Act (COPPA)

9.4.1. COPPA (effective April 21, 2000) applies to any on-line operator that collects personal information from children ***under 13.***

9.4.2. The rules adopted under COPPA spell out:

- what a Web site operator must include in a privacy policy,
- when and how to seek verifiable consent from a parent, and
- what responsibilities an operator has to protect a child's privacy and safety online.

9.5. Sarbanes-Oxley Act (SOX)

9.5.1. Most significant securities law since the Securities and Exchange Commission (1934).

9.5.2. SOX places substantial additional responsibilities on officers and directors of public companies & imposes significant criminal penalties for any violation.

9.5.3. Section 404 of SOX:

- Requires the management of a public company to assess the effectiveness of the company's internal control over financial reporting.
- Has the most relevance to information security with its requirement that management develops, document, test, and monitor its internal controls and its disclosure controls and procedures.

9.6. Red Flag Rules

9.6.1. The Red Flags Rule implement Sections 114 and 315 of the Fair and Accurate Credit Transaction (FACT) Act.

9.6.2. The Program must include reasonable policies and procedures for detecting, preventing, and mitigating identity theft and enable a creditor to:

- Identify relevant patterns, practices, and specific forms of activity that are red flags".
- Detect red flags that have been incorporated into the Program.
- Respond appropriately to any red flags that are detected to prevent and mitigate identity theft.
- Ensure the Program is updated periodically to reflect changes in risks from identity theft.

9.6.3. **Red Flag Categories.** Red flags that must be identified, detected, and responded to include the following:

- Alerts, notifications, or warnings from a consumer reporting agency
- Suspicious documents
- Suspicious personally identifying information, such as a suspicious address
- Unusual use of—or suspicious activity relating to—a covered account
- Notices from customers, victims of identity theft, law enforcement authorities, or other businesses about possible identity theft in connection with covered accounts.

Chapter- 4: Security Challenges of Convergence

1. Network Risk.

1.1. When physical security practitioners put physical security technology onto the network, they open the door to significant network-based security risk.

1.2. Types of ISS Risks.

ISS Risk	Definition	CIA Triad Applicable
Denial of services (DOS)	The ability of a malicious individual to stop the functioning of a computer-based system	Availability
Insertion of inaccurate data	Adding incorrect data into a database or file	Integrity
Data theft	Stealing data from a system	Confidentiality
Data modification	Changing data or information on a system	Integrity
Data destruction	Destroying data on a system	Availability

2. Communication Attack.

2.1. Types of Attacks.

2.1.1. **Social engineering:** Someone convinces a user to share his credentials to get on the network.

2.1.2. **Direct hacking:** Someone goes after a system, by directly accessing it via normal channels or by exploiting a vulnerability.

2.1.3. **Malware:** Someone attacks a system by installing software on it, either with the user's knowledge (usually hidden in other software or e-mail) or automatically, without the user's knowledge.

2.1.4. **Web attack:** Some portion of the Web interface with the user (like browsing to a Web page) allows for accessing the system.

2.2. Social Engineering.

2.2.1. Social engineering is the manipulation of people to get them to do something that weakens the security of the network.

2.2.2. One of the ways criminals use social engineering is to convince people to give up their user IDs and passwords.

2.3. Direct Hacking.

2.3.1. In a direct hacking attack, a hacker works with tools under his control to gain access to the network.

2.3.2. The hacker needs to identify what defences are in place and then defeat them.

2.3.3. The consequences are identical to those of social engineering. With full access to a system, a hacker can do whatever a system administrator can—that is, anything.

2.4. Malware.

2.4.1. The most insidious mechanism hackers use today to attack systems is malware.

2.4.2. Malware—viruses, worms, spyware, rootkits, Trojan horses, etc.—is designed to give the cybercriminal or hacker control of the computer on which it is installed.

2.4.3. Malware often circumvents preventive measures.

2.4.4. Malware can install itself either as part of other software, automatically when an e-mail is displayed, and by several other methods.

2.4.5. Mechanisms for gaining access by malware.

- A **general attack** focuses on obtaining access to any system and might give a hacker access to a system.

- A **focused attack** targets a specific individual and takes such steps as passing back information to an intruder or allowing for remote control of the system.

2.5. Web Attacks.

2.5.1. Web attacks can focus on clients (user workstations) or on servers (gaining direct, unauthorized access to system resources and information).

2.5.2. A Web attack is particularly dangerous because it can defeat almost every control.

2.5.3. Client attacks, when users are accessing the Web they can pick up malware simply by going to a compromised Web site.

2.5.4. Different types of flaws commonly found on Web sites, allowing hackers unauthorized access or control:

- **Injection.** Injection flaws, particularly Structured Query Language (SQL) injection, are common in Web applications. It allows an attacker to execute a command directly on a database contrary to allowed access rights.
- **Cross-site scripting (XSS).** A cross-site scripting error on a Web site allows an attacker to run malicious code from a second Web site (controlled by the cybercriminal) on the browser of the person viewing the first Web site.
- **Broken authentication and session management.** This class of vulnerabilities allows cybercriminals to compromise passwords, keys, or authentication tokens to assume a legitimate user's identity.
- **Insecure direct object references.** A failure to prohibit direct access to the internal object, files, directories, programs, etc.— on a Web server can lead to the illegitimate use of the server
- **Cross-site request forgery (CSRF).** Cross-site request forgery is an attack where the victim's browser is tricked into issuing a command to a vulnerable Web application
- **Security misconfiguration.** When a Web server or application is not configured in accordance with appropriate security requirements, it is then subject to attack and compromise affecting confidentiality, integrity, and availability.
- **Insecure cryptographic storage.** Cryptographic keys and other cryptography elements must be securely stored so they cannot be compromised.

INFORMATION ASSET PROTECTION GUIDELINE

1. Effective protection of information assets, whether in electronic, verbal, written, or any other form, involves these basic principles:

1.1. Classification and labelling information.

1.2. Handling protocols to specify use, distribution, storage, security expectations, declassification, return, and destruction/disposal methodology.

1.3. Training.

1.4. Incident reporting and investigation.

1.5. Audit/compliance processes and special needs (disaster recovery).

2. Key Terminology

2.1. **Assets:** Any real or personal property, tangible or intangible, that a company, organization, or individual owns that can be given or assigned a monetary value.

2.2. **Confidentiality:** Secrecy, the state of having the dissemination of certain information restricted.

2.3. **Copyright:** A property right in an original work of authorship (including literary, musical, dramatic, choreographic, pictorial, graphic, sculptural, and architectural work; motion pictures and other audio-visual works; and sound recordings) fixed in any tangible medium of expression, giving the holder the exclusive right to reproduce, adapt, distribute, perform, and display the work.

2.4. **Intellectual Property Rights (IPR):** A category of intangible rights protecting commercially valuable products of the human intellect. The category comprises primarily trademark, copyright, and patent rights, but also includes trade secret rights, publicity rights, moral rights, and rights against unfair competition.

2.5. **Patent:** Information that has the government grant of a right, privilege, or authority to exclude others from making, using, marketing, selling, offering for sale, or importing an invention for a specified period (**20 years from the date of filing**) granted to the inventor if the device or process is novel, useful, and nonobvious.

2.6. **Proprietary Information:** A property right or other valid economic interest in data resulting from private investment. Protection of such data from unauthorized use and disclosure is necessary in order to prevent the compromise of such property right or economic interest.

2.7. **Sensitive Information:** Information or knowledge that might result in loss of an advantage or level of security if disclosed to others.

2.8. **Service Mark:** A name, phrase, or other device used to identify and distinguish the services of a certain provider. Service marks identify and afford protection to intangible things such as services, as distinguished from the protection already provided for marks affixed to tangible things such as goods and products.

2.9. **Trade Secret:** All forms and types of financial, business, scientific, technical, economic, or engineering information, including patterns, plans, compilations, program devices, formulas, designs, prototypes, methods, techniques, processed, procedures, programs, or codes, whether tangible or intangible, and whether or how stored, compiled, or memorialized physically, electronically, graphically, photographically, or in writing if (a) the owner thereof has taken reasonable measures to keep such information secret; and (b) the information derives independent economic value, actual or potential, from not being generally known to, and not being readily ascertainable through proper means by, the public.

3. Information Asset Protection (IAP) Policy

3.1. Failure to take reasonable steps to protect assets from unauthorized use may make it difficult for an organization to obtain legal recourse in preserving its intellectual property rights if the information is compromised.

3.2. An organization's leadership should consider both the categories of information and the levels of information that represent protection objectives.

3.3. **Categories of information assets may include:**

Proprietary Information (Customer lists, marketing plans, pricing strategies, test results, etc.)	Physical Products (Prototypes, models, moulds, dyes and manufacturing equipment, etc.)
Trade Secrets	Trade Marks and Service Marks
Patent Information	Privacy Information (Personal data, evaluations, credit info, etc.)
Copyright Information	Regulated Information (Health Information, financial data, government classified, etc.)

3.4. **Levels of information may be determined by criteria such as:**

- 3.4.1. **Sensitivity.** This information includes that *which if disclosed* outside of trusted people and processes *would likely have a significant impact* on the organization's operations and business strategy.
- 3.4.2. **Criticality.** Critical information is *that upon which an organization relies to accomplish its mission* and support business decisions.
- 3.4.3. Other levels include **confidential, restricted, limited, non-public**, and others.

4. IAP Policy Implementation & Recommended Practices. The following principles form the foundation of an effective IAP policy: **identifying, valuating, classifying, and labelling information assets; need-to-know controls; privacy protection; security awareness and training; information asset management; and investigating loss or compromise.**

4.1. Identifying Information Asset. The first step in implementing an IAP is to identify the information that may need to be labeled and protected.

4.2. Valuating Information Assets. After information is identified, an organization needs to perform a valuation process to determine importance and criticality to the enterprise.

4.3. Classifying Information Assets. An organization must establish a classification system that assigns a value to critical information.

4.4. Labelling Information Assets. All identified assets should prominently display the appropriate classification and level in whatever media it appears.

4.5. Need-To-Know Controls.

4.5.1. An employee's access should be based on his or her current job function and a need-to-know basis, not solely on a position or management level.

4.5.2. Use categories and levels of information to aid in defining need-to-know controls.

4.5.3. Apply methods/layers of protective measures to information assets appropriate to their categories and levels.

4.5.4. Ensure that successive methods/layers of protective measures complement the organization's overall policy and provide the balance between the conduct of the business and approved accessibility.

4.6. Privacy Protection.

4.6.1. Establish specific privacy policies and designate an employee responsible for implementing and managing the privacy program.

4.6.2. Evaluate privacy information relating to employees, partners, vendors, customers, and others and determine legal and regulatory requirements.

4.6.3. Ensure systems are in place to ensure employee and customer privacy is not compromised.

4.6.4. Provide a mechanism to investigate compromises of privacy information (including identity theft) and report the incidents to affected individuals or organizations (victims) as appropriate.

4.6.5. Conduct program audits to ensure privacy policies are practiced effectively.

4.7. Information security Awareness & Training. Almost invariably, security awareness and training is one of the most cost effective measures that can be employed to protect corporate and organizational information assets.

4.7.1. Determine the need for and scope of an Information Security Awareness Training program within the organization based on a comprehensive risk assessment and the nature of the business.

4.7.2. Consider developing and delivering tailored security awareness training for all individuals in a trusted relationship.

4.7.3. Include non-employees such as part-time personnel, temporary employees, consultants, sub-contractors and on-site vendors in such training.

4.7.4. Deliver awareness training on a recurring basis and via multiple modes to effectively reach all appropriate personnel.

4.7.5. Whenever possible, information security awareness and training should be documented.

4.8. Investigating Loss or Compromise. Appropriate investigative techniques should be used at all times and legal considerations taken into account when developing an investigative plan.

4.8.1. Investigation

- Establish an investigative plan and coordinate with counsel.
- Thoroughly investigate known and suspected compromises of information.
- Identify investigative resources that are available (both internal and external) or may be needed including forensic laboratory support and various expert capabilities.
- Establish and maintain effective liaison relationships with law enforcement and investigative service providers as well as various information sources

4.8.2. Damage Assessment

- To the extent possible and as soon as possible, determine exactly what information has been compromised.
- Determine the implications of the compromise in terms of economic loss, research/ project delays, operational impact, corporate image, shareholder confidence, legal liability, and corporate relationships (partners, vendors, suppliers, subcontractors, etc.).

- Determine the actual and potential impact of the compromise on other corporate projects and initiatives.
- Report actual and potential impact to an appropriate level of management.

4.8.3. **Root Cause Analysis**

- Attempt to identify any systemic problems or existing business practices that would allow or contribute to the compromise of sensitive information.
- Maintain easily accessible documentation (or an automated database) on incidents (including allegations and suspected incidents) related to the compromise or suspected compromise of sensitive information.
- Following a root cause analysis, identify and implement appropriate corrective actions and follow-up to adjust policies and practices that contributed to or facilitated the loss incident.

MISC ASPECTS

1. Eavesdropping Tactics and Equipment

- 1.1. The term eavesdropping today should include both **wiretapping and bugging**.
- 1.2. **Wiretapping** is the interception of communication over a wire without the consent of the participants and requires physical entry into the communication circuit.
- 1.3. **Bugging** is the interception of communication without the consent of the participants by means of electronic devices and without penetration of a wire.

2. **Technical Countermeasure Sweeps**. As part of a robust security program, or if a company suspects that eavesdropping is occurring, technical countermeasure sweeps should be conducted. Technical countermeasure sweeps can be categorized into three categories—**physical search, telephone search, and electronic search**.

2.1. **Physical Search**. A physical search is detailed, time consuming, and expensive and should be conducted in specific areas only. Some of the key points of a physical search are as follows:

- 2.1.1. Walls are examined in detail for holes, mismatched paint, and new plaster or sheetrock.
- 2.1.2. All furniture is removed and examined.
- 2.1.3. Space above a dropped ceiling (plenum) is examined.
- 2.1.4. All wiring, including optical fibres, is traced and accounted for. Any wire that is not in use is to be removed.

2.2. **Telephone Search**. A telephone search should be done by a technician who is familiar with the specific equipment. Some of the key points of a telephone search are as follows:

- 2.2.1. The telephone distribution room wiring is verified.
- 2.2.2. Examine all connections to the wiring closets and junction boxes and verify that they are properly connected and have not been modified.
- 2.2.3. Handsets are to be examined for drop-in transmitters or wiring alterations.
- 2.2.4. All cables are inspected for unusual attachments or bulges.

2.3. **Electronic Search**. An electronic search is a search of the radio frequency spectrum to detect any unauthorized emanations from the area being examined. A key point to remember is that no remote device or technique is guaranteed to find a well-installed device put in place by an experienced technician. Some of the key equipment and methods used for an electronic search are as follows:

2.3.1. A nonlinear junction detector is used to locate a semiconductor device that is dead by transmitting a microwave signal.

2.3.2. Time-domain reflectometry takes an electronic picture of a telecommunications line at a given time, which is compared to the same telecommunications line at a future time.

2.3.3. A countermeasure radio receiver searches the radio spectrum to isolate and identify a signal.

2.3.4. A “**pen register**” is a device used to monitor telephone calls by providing a record of all numbers dialled from a particular phone. It provides both the date and time a call was made.

3. **Types of Microphones.** The following are some basic facts concerning types of microphones used:

3.1. A **carbon microphone** is commonly used in the mouthpiece of a standard telephone handset. A power source is required to supply the necessary voltage.

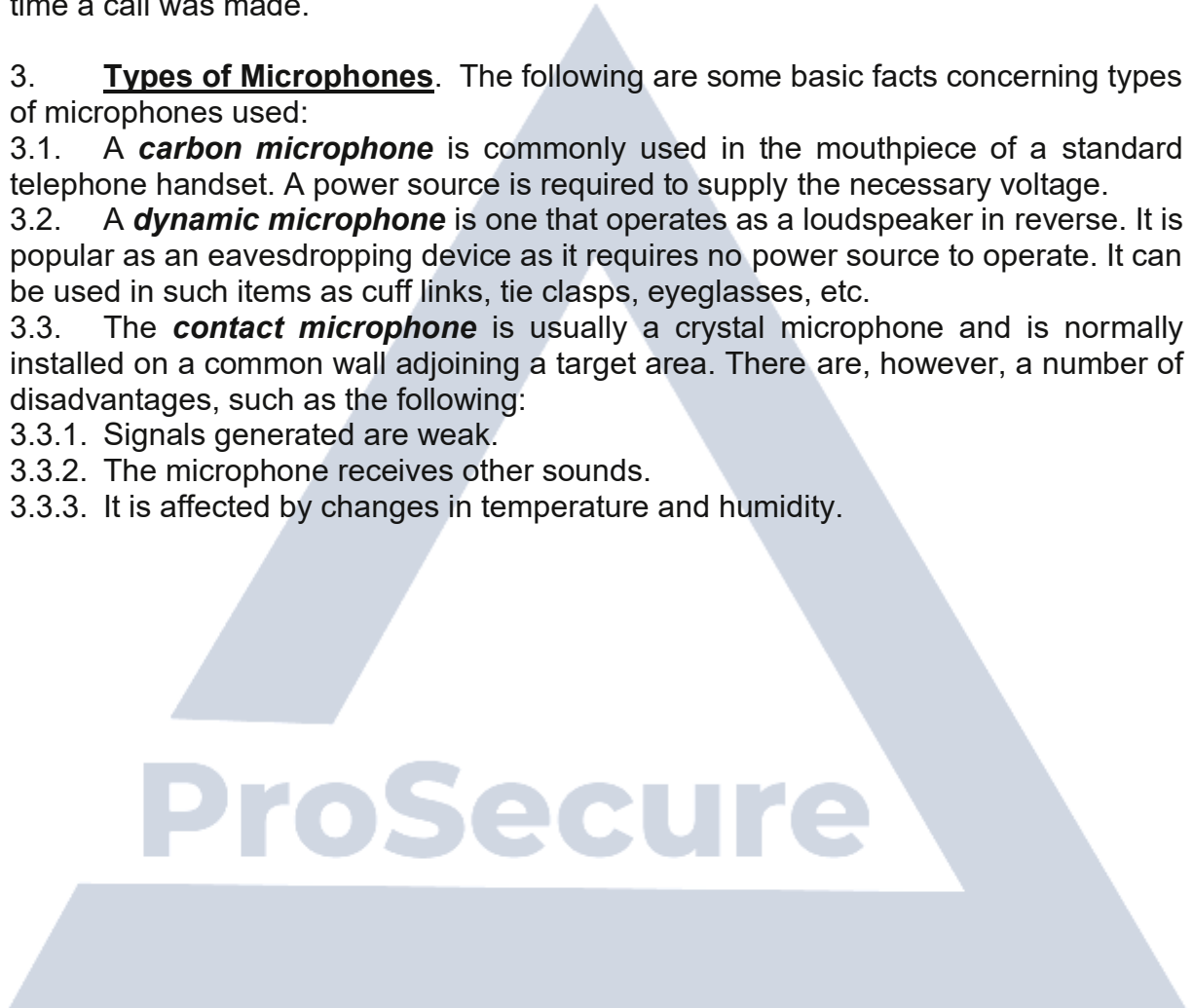
3.2. A **dynamic microphone** is one that operates as a loudspeaker in reverse. It is popular as an eavesdropping device as it requires no power source to operate. It can be used in such items as cuff links, tie clasps, eyeglasses, etc.

3.3. The **contact microphone** is usually a crystal microphone and is normally installed on a common wall adjoining a target area. There are, however, a number of disadvantages, such as the following:

3.3.1. Signals generated are weak.

3.3.2. The microphone receives other sounds.

3.3.3. It is affected by changes in temperature and humidity.

The logo features a large, light blue triangle in the background. Inside the triangle, the word "ProSecure" is written in a bold, sans-serif font. Below the triangle, the words "Process | Performance | Protection" are written in a smaller, sans-serif font.

ProSecure

Process | Performance | Protection